

IAM em Profundidade

Policies, Permission Boundaries e IAM Avançado

AWS Certified Developer Associate

Instrutor: Marlon Anesi

Tipos de Policies no IAM

Identity-Based

- Attached a users, groups, roles
- Managed (AWS ou Customer)
- Inline (embutida no principal)
- Define O QUE o principal pode fazer

Resource-Based

- Attached ao recurso (S3, SQS, Lambda)
- Inline apenas (sem managed)
- Inclui campo Principal
- Permite cross-account access

Permission Boundary

- Limite máximo de permissões
- Não concede permissões por si só
- Used com users e roles
- Effective: intersection de policies

Evaluation Logic: Deny explícito > Allow > Deny implícito (tudo negado por padrão)

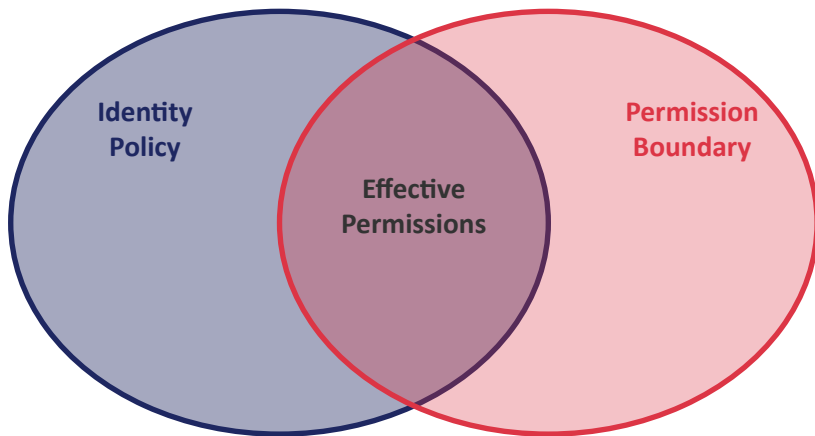
Estrutura de uma IAM Policy (JSON):

```
{ "Version": "2012-10-17",  
  "Statement": [{ "Effect": "Allow",  
    "Action": ["s3:Get*"], "Resource": "*" }]}
```

Elementos obrigatórios: Version, Statement
Statement: Effect (Allow/Deny), Action, Resource
Optional: Principal (resource-based), Condition

Permission Boundaries em Detalhe

Como Permission Boundary funciona:



Regras Críticas:

- Efetiva = Identity Policy AND Boundary
- Boundary não CONCEDE permissões
- Boundary define o MÁXIMO possível
- Identity policy pode ter mais, não importa
- SCP (Service Control Policy) tb limita no Org
- Usada para delegar criação de roles com segurança

Caso de Uso Clássico no Exame:

Cenário: Admin cria IAM user com uma permission boundary que permite apenas ações de S3.
O user recebe uma identity policy com AdministratorAccess.
Resultado: user só consegue executar ações de S3, pois a boundary é o limite máximo.

Managed vs Inline + Políticas de Organização

Tipo	AWS Managed	Customer Managed	Inline
Criacao	AWS cria e mantém	Você cria e mantém	Embutida no principal
Reutilizacao	Sim (qualquer conta)	Sim (mesma conta)	Nao (1 para 1)
Versionamento	Nao (AWS gerencia)	Sim (ate 5 versoes)	Nao
Uso recomendado	Inicio / rapido	Producao	Casos muito especificos
Ao deletar principal	Policy permanece	Policy permanece	Policy e deletada

Service Control Policies (SCP) - AWS Organizations:

Nível de aplicação: Organization, Organizational Unit (OU) ou conta individual

Função: Limita o máximo de permissões que contas membro podem ter

Não afeta: Management account (conta raiz da organização)

Combinado com: Identity policies para calcular permissão efetiva

Crítico: SCP Deny sempre vence, mesmo com Admin na conta membro

Boas Práticas e Casos de Uso

Quando usar Customer Managed

- Controle total de versão e mudancas
- Políticas de produção críticas
- Auditoria e compliance rigoroso
- Reutilizar em múltiplos principals
- Aplicar em projetos de larga escala

Quando usar Permission Boundary

- Delegar criação de roles para devs
- Impedir escalação de privilégios
- Ambientes multi-time (teams)
- Sandbox accounts controladas
- Conformidade com frameworks (SOC2)

Boas Práticas Essenciais:

- Princípio do Menor Privilegio: sempre comece negando tudo e adicione apenas o necessário
- Evite * em Action e Resource em policies de produção: seja específico
- Use grupos IAM para gerenciar permissões de usuários (não atribua policies diretamente)
- Rotacione credenciais regularmente e habilite MFA para todos os usuários

Pontos-chave para o Exame

1

Identity vs Resource-Based

Identity: attached ao principal. Resource: attached ao recurso com campo Principal. Resource-based permite cross-account.

2

Permission Boundary

Define o LIMITE MÁXIMO. Effective = Identity AND Boundary. Boundary sozinha não concede nada.

3

Managed vs Inline

Customer Managed: versioning, reutilizável, persiste após deletar principal. Inline: deletada junto com o principal.

LEMBRE-SE: Se questão fala 'permissão máxima' ou 'delegar sem escalção' > pense Permission Boundary!